

HiveForce Labs

# THREAT ADVISORY

 **ATTACK REPORT**

## **The Windows Update Deception: How ClickFix Lures Unleash Stealthy Stealers**

Date of Publication

November 26, 2025

Admiralty Code

A1

TA Number

TA2025360

# Summary

**Attack Discovered:** October 2025

**Targeted Countries:** Worldwide

**Malware:** LummaC2, Rhadamanthys, Stego Loader

**Attack:** The ClickFix campaign uses cleverly crafted “verification” and fake Windows Update pages to trick people into running a malicious command that silently launches a multi-stage infection chain. Behind these convincing screens, attackers hide their payloads inside PNG image pixels, decrypt code on the fly, and inject stealthy LummaC2 or Rhadamanthys stealers into the system, all while making the victim believe they're simply completing an update. Although the operation relies on sophisticated tricks such as steganography and reflective .NET loading, its success still hinges on a single manual action by the user. This involves awareness, skepticism toward unexpected update prompts, and restricting dangerous tools like mshta.exe to break the attack before it begins.

## 🔪 Attack Regions



© Australian Bureau of Statistics, GeoNames, Microsoft, NavInfo, Open Places, OpenStreetMap, Overture Maps Foundation, TomTom, Zenrin

Powered by Bing

# Attack Details

## #1

A new wave of attacks is leveraging [ClickFix](#)-style lures to trick victims into manually executing commands that launch a multi-stage malware chain. These campaigns deliver well-known infostealers like LummaC2 and Rhadamanthys, using creative evasion tactics such as hiding malicious code inside the pixel data of PNG images. Earlier waves relied on generic “Human Verification” prompts, but attackers have now adopted a far more convincing trick, a full-screen fake Windows Update interface that mimics the familiar blue update screen and guides users into running a malicious command without realizing it.

## #2

Since October, multiple websites following the ClickFix pattern have been uncovered. One example, now offline, used a verification page that automatically copied a malicious mshta command into the victim’s clipboard, prompting them to paste it into the Windows Run box. A deep look at the lure’s source code reveals several layers of obfuscation. Portions of the JavaScript are encrypted and only decrypted at runtime. The second-stage script hides inside a variable named ENC, which is unlocked through a sequence of functions that convert, decode, XOR, and ultimately reconstruct a plaintext script injected through a temporary Blob URL. After execution, the Blob is revoked, leaving minimal forensic traces.

## #3

The malware chain begins with mshta.exe fetching a remote JScript payload, which then pulls down PowerShell code padded with junk instructions to slow analysis. Once cleaned, this PowerShell script decrypts a .NET assembly directly in memory. This assembly acts as the loader for the next stage, and itself contains encrypted logic, misleading function names, and AES-protected strings. Using predefined keys, the malware decrypts internal configuration and logic before beginning its next move: pulling shellcode hidden within a PNG file using steganography.

## #4

The next stage focuses on extracting this hidden shellcode from manipulated image pixels. Each byte is recovered through careful XOR operations that depend on precise pixel stride values to avoid corruption. Once decoded, the loader prepares and injects the shellcode into explorer.exe, calling essential Windows APIs to carry out process injection. The final stage reveals that the shellcode is packaged using Donut.

## #5

The campaign’s Windows Update-themed lure is especially deceptive. It forces the victim’s browser into full-screen mode, displays a fake Windows update screen, and instructs users to press Win+R and paste a command, thinking it is part of an update step. Under the hood, the attack chain mirrors previously documented Human Verification lures, beginning with mshta.exe, pulling down PowerShell, and ultimately loading the steganographic .NET loader.

## #6

The attackers shift their first-stage URLs frequently. The campaign’s use of steganography makes detection difficult, but the attack still depends on convincing victims to manually run commands, an area where user awareness can break the chain.

# Recommendations



**Strengthen User Awareness Around “Clickfix”-style Tricks:** Explain to employees and users that no legitimate Windows update or verification page will ever ask them to press Win+R or paste a command into the Run box. Regularly share screenshots and examples of these lures so people can instantly recognize the red flags.



**Block the Misuse of Mshta.Exe and Scripting Engines:** Use endpoint controls or application-allowlisting to block or restrict mshta.exe, PowerShell with unrestricted execution, and other Windows script hosts. These tools are rarely used by regular users but heavily abused by attackers.



**Implement Strong Web Filtering and DNS Protection:** Use DNS filtering or secure web gateways to block access to suspicious or newly registered domains commonly used in these attacks. This can stop the infection chain before it begins.



**Monitor Clipboard, Run-box, and Scripting Activity:** Enable logging for clipboard access, suspicious use of Win+R, and unusual command-line arguments. These patterns often indicate ClickFix-like attempts.



**Enhance Endpoint Protection:** Deploy next-generation antivirus (NGAV) and endpoint detection & response (EDR) solutions to identify and block malware. Leverage behavioral analysis and machine learning-based detection to spot suspicious activity.



## Potential MITRE ATT&CK TTPs

|                                          |                                             |                                                          |                                                        |
|------------------------------------------|---------------------------------------------|----------------------------------------------------------|--------------------------------------------------------|
| <b><u>TA0001</u></b><br>Initial Access   | <b><u>TA0002</u></b><br>Execution           | <b><u>TA0005</u></b><br>Defense Evasion                  | <b><u>TA0009</u></b><br>Collection                     |
| <b><u>TA0010</u></b><br>Exfiltration     | <b><u>TA0011</u></b><br>Command and Control | <b><u>T1566</u></b><br>Phishing                          | <b><u>T1027</u></b><br>Obfuscated Files or Information |
| <b><u>T1027.003</u></b><br>Steganography | <b><u>T1204</u></b><br>User Execution       | <b><u>T1204.004</u></b><br>Malicious Copy and Paste      | <b><u>T1218</u></b><br>System Binary Proxy Execution   |
| <b><u>T1218.005</u></b><br>Mshta         | <b><u>T1115</u></b><br>Clipboard Data       | <b><u>T1059</u></b><br>Command and Scripting Interpreter | <b><u>T1059.007</u></b><br>JavaScript                  |



|                                                         |                                    |                               |                                       |
|---------------------------------------------------------|------------------------------------|-------------------------------|---------------------------------------|
| <b>T1140</b><br>Deobfuscate/Decode Files or Information | <b>T1059.001</b><br>PowerShell     | <b>T1132</b><br>Data Encoding | <b>T1132.001</b><br>Standard Encoding |
| <b>T1055</b><br>Process Injection                       | <b>T1204.001</b><br>Malicious Link | <b>T1036</b><br>Masquerading  | <b>T1105</b><br>Ingress Tool Transfer |
| <b>T1041</b><br>Exfiltration Over C2 Channel            |                                    |                               |                                       |

# Indicators of Compromise (IOCs)

| TYPE    | VALUE                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Domains | 1e442295[.]consent-verify[.]pages[.]dev,<br>5df43170[.]consent-verify[.]pages[.]dev,<br>3b4ce6c9[.]consent-verify[.]pages[.]dev,<br>6b04000[.]consent-verify[.]pages[.]dev,<br>f6b04000[.]consent-verify[.]pages[.]dev,<br>3e6eb645[.]consent-verify[.]pages[.]dev,<br>d9e71335[.]consent-verify[.]pages[.]dev,<br>hypudyk[.]shop,<br>squatje[.]su/asdasd,<br>bendavo[.]su/asdsa,<br>conxmsw[.]su/vcsf,<br>narroxp[.]su/rewd,<br>squeaeu[.]su/qwe,<br>ozonelf[.]su/asd,<br>exposqw[.]su/casc,<br>squatje[.]su/asdasd,<br>vicareu[.]su/bcdf,<br>xmcniiadpwqw[.]site,<br>xcvcxoipoeww[.]site,<br>xoiiasdpsdoasdpojas[.]com,<br>xpoalswwkjddsljsy[.]com,<br>galaxyswapper[.]pro,<br>cmevents[.]live,<br>cmevents[.]pro,<br>cosmicpharma-bd[.]com,<br>groupewadeseconomy[.]com,<br>sportsstories[.]gr,<br>virhtechgmbh[.]com |

| TYPE | VALUE                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URLs | hxxp[:]//81[.]90[.]29[.]64/ebc/rps[.]gz,<br>hxxp[:]//corezea[.]com/ebc (81[.]90[.]29[.]64),<br>hxxp[:]//141[.]98[.]80[.]175/tick[.]odd,<br>hxxp[:]//141[.]98[.]80[.]175/gpsc[.]dat,<br>hxxp[:]//141[.]98[.]80[.]175/ercx[.]dat,<br>hxxp[:]//141[.]98[.]80[.]175/rtdx[.]dat,<br>hxxp[:]//141[.]98[.]80[.]175/very[.]dat,<br>hxxp[:]//securitysettings[.]live,<br>hxxp[:]//xoiiasdpsdoasdpojas[.]com,<br>hxxtp[:]//94[.]74[.]164[.]136/fifx[.]odd |

## References

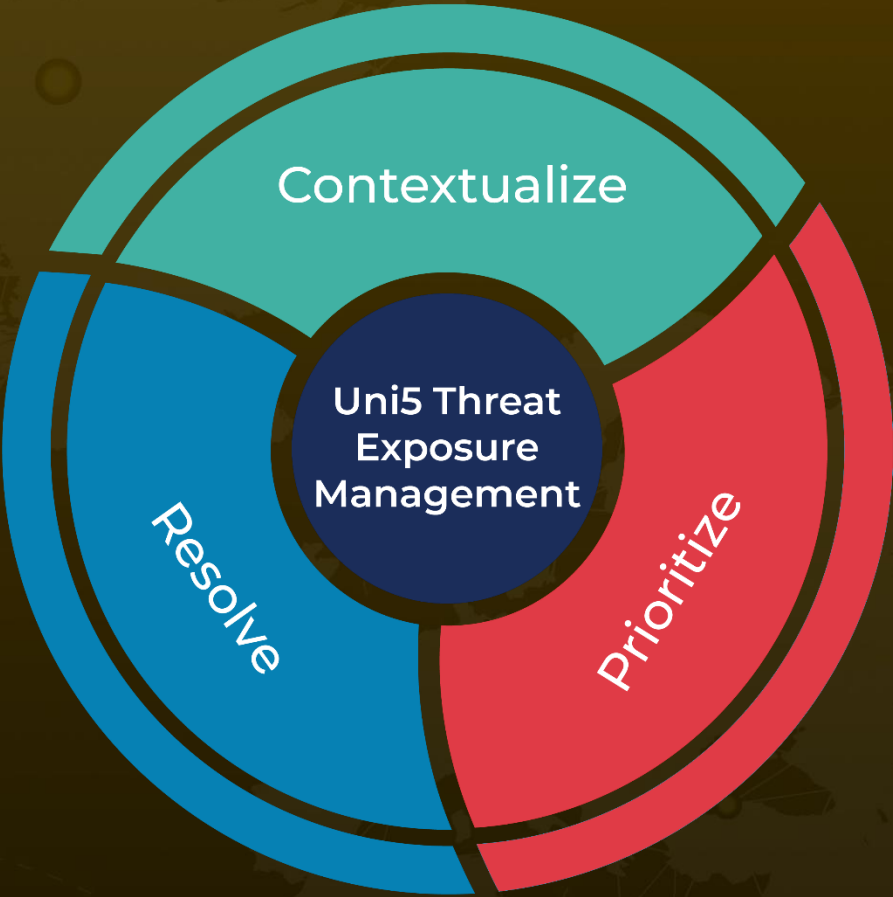
<https://www.huntress.com/blog/clickfix-malware-buried-in-images>

<https://hivepro.com/threat-advisory/coldrivers-clickfix-campaign-targets-civil-voices/>

# What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

November 26, 2025 • 9:00 AM

© 2025 All Rights are Reserved by Hive Pro



More at [www.hivepro.com](http://www.hivepro.com)